

HarborPoint Health

Ransomware Attack Response Project

Preparedness, Detection, Investigation, Containment, Recovery and Continuous Improvement

1. Executive Summary

HarborPoint Health is a regional not-for-profit healthcare system whose clinical operations depend heavily on interconnected digital systems, including electronic health records (EHR), picture archiving and communication systems (PACS), laboratory interfaces, authentication services and vendor-hosted services. The fictional ransomware incident encrypted key clinical systems and involved patient-data exfiltration, causing operational disruption and forcing clinical staff to use paper workflows.

The proposed response programme focuses on reducing the time between detection and containment, limiting lateral movement, protecting recoverability through immutable and offline backups, improving security visibility through centralized logging and endpoint detection, operationalising threat intelligence through MISP, and exercising the incident-response and recovery plans. The design is consistent with healthcare-sector guidance emphasizing incident preparedness, asset inventory, network segmentation, centralized logging, endpoint detection, secure backups and recovery testing. HHS identifies these as healthcare cybersecurity performance goals, while its ransomware guidance emphasizes frequent backups, offline protection and periodic restoration testing.

2. Problem Statement and Business Impact

The principal weaknesses are detection latency, incomplete network segmentation, inadequate backup resilience, weak incident-response coordination and limited threat-intelligence sharing. These weaknesses allowed an attacker to establish an initial foothold, obtain credentials, move laterally, exfiltrate patient data and deploy ransomware across important systems.

- Clinical impact: reduced availability of EHR, PACS and other clinical applications can delay diagnosis, treatment and access to patient information.
- Operational impact: paper workflows, patient delays, system restoration work and potential service diversion increase workload and cost.
- Security impact: credential theft and flat network architecture can allow ransomware to move between administrative and clinical environments.
- Data-protection impact: exfiltration creates a confidentiality incident in addition to the availability and integrity problems caused by encryption.
- Legal and reputational impact: a healthcare breach may require regulatory assessment and notification and can reduce patient trust.

3. Project Objectives

Objective	Target	Measure
Reduce detection-to-containment time	≤ 1 hour for high-severity incidents	MTTD, containment time and SLA percentage
Protect critical backups	Immutable/offline EHR and	Quarterly restore tests with

	PACS backups	100% successful validation
Limit ransomware spread	≤ 3 hosts per incident by design	Micro-segmentation and red-team validation
Improve ransomware detection	Splunk + EDR + YARA	True positives, false positives and ATT&CK coverage
Operationalise threat intelligence	MISP integrated with Splunk/SOAR	IoC ingestion, enrichment and automated response
Exercise response and recovery	Tabletop plus live recovery exercise	Exercise scorecard, restore time and remediation closure rate

4. Asset Inventory and Criticality

HarborPoint should maintain an authoritative inventory of clinical, security, identity, network and recovery assets. HHS healthcare cybersecurity goals specifically include asset inventory and system/data classification.

Asset	Purpose	Criticality	Importance
EHR	Patient records and clinical information	Critical	Required by clinicians for diagnosis, treatment and continuity of care.
PACS	Stores and provides medical imaging	Critical	Imaging is essential for diagnosis and treatment.
Active Directory	Identity, authentication and access control	Critical	Compromise can enable privilege escalation and lateral movement.
Laboratory Information System	Manages laboratory results and workflows	Critical	Supports clinical decisions and test-result availability.
Staff Workstations	Provides access to clinical and administrative applications	High	A compromised endpoint can become the initial foothold or lateral-movement point.
VPN	Provides remote access	High	A compromised remote-access service or account can provide external entry.
Firewall	Controls network traffic between trust zones	Critical	Supports segmentation and blocks malicious network activity.
Backup Servers	Stores recovery copies of critical data	Critical	Recovery depends on reliable, isolated backups.
Email System	Business and clinical communication	High	Email is a common route for phishing and credential theft.
Splunk SIEM	Centralized security logging and correlation	High	Provides visibility and supports detection and investigation.

5. Proposed Network Segmentation

HarborPoint should replace the flat network model with security zones. Mission-critical clinical assets should be isolated from general user and administrative networks. HHS states that network segmentation can contain ransomware spread, isolate critical systems and reduce lateral movement.

- Internet/DMZ: externally exposed services and controlled vendor access.
- User network: standard staff workstations with restricted east-west communication.
- Clinical network: EHR, PACS and clinical application services.
- Identity/security zone: Active Directory and security-management infrastructure with tightly controlled administration.
- Backup/recovery zone: immutable/offline backup infrastructure separated from normal user traffic.
- Vendor access zone: third-party systems and remote connections with least-privilege, MFA and monitored access.
- Management zone: administration interfaces for security and infrastructure devices.

Validation should use controlled attack simulations to verify that a compromised workstation cannot freely reach clinical servers or backup infrastructure.

6. Preparation Phase

6.1 Asset and dependency mapping

Catalogue hardware, virtual machines, cloud/vendor services, network devices, identities and data flows. Mark Tier 0/life-safety and other critical services. Document dependencies such as EHR-to-identity, PACS-to-storage and clinical applications-to-laboratory interfaces.

6.2 Telemetry and logging

- Windows Event Logs and Sysmon
- Active Directory authentication and privilege events
- Firewall, VPN, DNS and proxy logs
- EDR process and endpoint telemetry
- Server and application logs
- Backup-system logs
- Relevant vendor and cloud-service logs

Send required telemetry to Splunk, establish normal baselines, and define retention and access controls.

6.3 Identity protection

- Use MFA for remote access and privileged operations where technically feasible.
- Separate standard user accounts from privileged administrator accounts.
- Use unique credentials and promptly revoke access when personnel leave.
- Monitor unusual authentication, privilege escalation and service-account activity.

These controls align with HHS healthcare cybersecurity goals covering MFA, unique credentials and separation of user and privileged accounts.

6.4 Backup and recovery

Maintain frequent, immutable and offline/isolated backups of EHR, PACS and other Tier 0 services. Restrict administrative access to backups, monitor backup deletion attempts and perform scheduled

restoration tests. HHS ransomware guidance emphasizes that backups should be protected from ransomware, including consideration of offline copies, and that test restorations should be performed periodically.

6.5 Incident-response preparation

- Define incident severity levels and escalation thresholds.
- Assign decision owners for technical response, clinical continuity, legal/privacy, communications and vendor management.
- Prepare secure emergency communications and an incident war room.
- Maintain contact details for critical vendors, law enforcement, insurers and relevant partners.
- Run tabletop exercises and recovery drills.

7. Detection and Triage

The simulated trigger is a combination of suspicious endpoint and network behaviours: attempts to delete Volume Shadow Copies, mass file-renaming/encryption behaviour and an unusual outbound data transfer. Combining multiple signals reduces reliance on a single indicator.

7.1 Splunk correlation logic

A conceptual detection can correlate endpoint events with file activity and network indicators. A simplified example is:

```
index=winevent OR index=endpoint
(EventCode=7045 OR Image="*vssadmin.exe" OR Image="*wmic.exe" OR
file_name="*.locked")
| stats count by host, process, user, src_ip, dest_ip
| where count > 50
```

This is a conceptual query rather than a production-ready detection. In a real environment, the field names, indexes, thresholds and data models would be tuned against HarborPoint's actual telemetry. A production rule should combine process execution, file-encryption behaviour, privilege activity and network anomalies and should include exclusions for legitimate administrative activity.

7.2 Triage

- Confirm the alert is associated with a real endpoint and user.
- Review process trees and parent/child relationships.
- Check whether shadow copies or backup-related services were modified.
- Identify suspicious authentication and lateral-movement activity.
- Check outbound connections and data-transfer volume.
- Determine whether other hosts show the same indicators.
- Assign severity and open a high-severity incident when confidence is high.

8. Automated and Manual Containment

When confidence is high, SOAR can execute predefined actions while the SOC retains oversight for disruptive actions.

- Isolate the suspected endpoint using EDR/NAC.
- Disable or restrict compromised accounts and revoke active sessions.
- Block confirmed malicious IP addresses and domains.
- Restrict affected network segments to prevent lateral movement.

- Preserve volatile and disk evidence before destructive remediation where practical.
- Search for the same IoCs across the environment.
- Escalate to clinical, legal/privacy, communications and executive teams.

9. Investigation and Forensics

9.1 Endpoint investigation

Collect process lists, process trees, network sockets, scheduled tasks, services, persistence mechanisms and relevant files. Preserve evidence using a documented chain of custody and calculate hashes for acquired evidence.

9.2 Memory and disk analysis

- Volatility: analyse memory for processes, network connections and other volatile artefacts.
- Autopsy/Sleuth Kit: examine disk images, file-system activity, deleted files and timestamps.
- YARA: scan collected files, mounted disk images and appropriate memory artefacts for known or custom ransomware patterns.

9.3 YARA example

```
rule suspicious_ransomware_dropper {
  meta:
    author = "HarborPoint SOC"
    description = "Detects suspect ransomware dropper patterns"
  strings:
    $s1 = "EncryptedBy" ascii
    $s2 = "PAY-TO-RECOVER" ascii
  condition:
    any of them
}
```

This is an educational example. Real YARA rules should be tested against known-good and known-bad samples, tuned to reduce false positives, and managed through change control.

9.4 Network investigation

Use Zeek to create searchable network metadata and Wireshark for packet-level analysis. Investigate DNS requests, connection destinations, unusual protocols, large outbound transfers, HTTP POST activity and suspicious TLS sessions. The aim is to determine whether data was exfiltrated and identify infrastructure associated with the intrusion.

9.5 Timeline reconstruction

Correlate EDR, Splunk, Active Directory, VPN, firewall, DNS, Zeek and packet-capture evidence into a chronological timeline. The timeline should identify initial access, credential compromise, privilege escalation, lateral movement, exfiltration, ransomware deployment and detection.

10. MISP Threat Intelligence

MISP should act as the operational threat-intelligence layer. IoCs discovered during investigation can be recorded, tagged, enriched and shared with approved partners. Relevant intelligence can be fed into Splunk for correlation and, where confidence is sufficient, into SOAR workflows for containment.

- Collect hashes, domains, IP addresses and other relevant indicators.
- Record source, confidence, timestamps and context for each indicator.
- Map indicators and behaviours to relevant threat techniques.
- Push validated intelligence into Splunk.
- Use automated enrichment to support triage.
- Share sanitized, approved intelligence with appropriate healthcare information-sharing communities.

11. Eradication

- Remove confirmed persistence mechanisms.
- Patch or otherwise remediate the exploited vulnerability.
- Rotate compromised credentials and secrets.
- Reimage affected endpoints from trusted clean images where appropriate.
- Validate administrative accounts and access paths.
- Search the environment for remaining IoCs and persistence.
- Keep compromised systems isolated until investigation and eradication criteria are satisfied.

12. Recovery

Recovery should prioritize life-safety and Tier 0 clinical services. Restored systems should be validated in an isolated environment before being returned to production.

- Confirm the attacker no longer has access.
- Verify backup integrity and select the appropriate recovery point.
- Restore EHR and PACS first according to clinical priorities.
- Validate application functionality and data integrity.
- Have clinical stakeholders confirm that workflows function correctly.
- Reconnect systems gradually and monitor closely.
- Measure actual recovery time against RTO and data loss against RPO.

13. Communications and Legal/Regulatory Response

The incident-response plan should define internal communication, clinical continuity communications, executive escalation, vendor notification, legal/privacy assessment and external communications. Because the scenario is U.S.-based and references HIPAA, HarborPoint should perform the applicable HIPAA breach assessment and notification processes with qualified privacy/legal personnel. HHS explains that ransomware affecting ePHI requires a documented risk assessment and that the assessment should consider whether ePHI was actually acquired or exfiltrated.

Law-enforcement coordination should be included in the playbook. The FBI advises ransomware victims to contact their local FBI field office or report through IC3 and states that it does not support paying a ransom.

14. Post-Incident Review

- Complete a root-cause analysis.
- Document the initial access vector and attack path.
- Identify detection blind spots.
- Update Splunk correlation searches and dashboards.
- Update YARA rules and endpoint detection content.
- Add validated IoCs and TTPs to MISP.
- Harden segmentation and privileged access.
- Improve backup isolation and restoration testing.
- Review third-party/vendor controls.
- Run tabletop and purple-team exercises.
- Track remediation actions to closure.

15. KPIs and Success Criteria

KPI	Target	How measured	Reason
MTTD	≤ 1 hour	Splunk/EDR alert-to-confirmation timestamps	Reduces attacker dwell time
Containment SLA	≥ 90% within 4 hours	Incident ticket and SOAR timestamps	Measures response effectiveness
Backup restore success	100% of quarterly tests	Restore test reports and integrity checks	Demonstrates recoverability
Lateral movement reduction	≥ 70%	Controlled attack simulation and network telemetry	Measures segmentation effectiveness
Ransomware detection coverage	Increasing coverage with acceptable false positives	ATT&CK mapping and detection tests	Measures visibility
Remediation closure	High-priority actions closed on schedule	RCA/action tracker	Prevents repeat failures

16. End-to-End SOC Playbook

1. Alert received from EDR/Splunk.
2. SOC validates the alert and assigns severity.
3. Contain high-confidence compromised hosts immediately.
4. Revoke compromised sessions and restrict accounts.
5. Search for related IoCs across the environment.
6. Preserve forensic evidence.
7. Investigate initial access, privilege escalation, lateral movement and exfiltration.
8. Eradicate persistence and remediate vulnerabilities.
9. Validate that the attacker has been removed.
10. Restore critical systems from protected backups.
11. Validate clinical functionality and data integrity.
12. Monitor restored systems.
13. Complete breach/legal assessment and required notifications.
14. Conduct post-incident review and close remediation actions.

17. Conclusion

HarborPoint's ransomware resilience programme should be treated as an ongoing capability rather than a one-time technical deployment. The most important improvements are rapid detection, strong segmentation, protected and tested backups, coordinated response, endpoint and network visibility, and operational threat intelligence. The combination of Splunk, EDR, YARA, Wireshark/Zeek, MISP, forensic tooling and tested recovery procedures provides a layered approach that addresses the weaknesses identified in the scenario. The proposed controls also align with HHS healthcare cybersecurity guidance on asset inventory, segmentation, centralized logging, endpoint detection and incident preparedness.

18. References

- U.S. Department of Health and Human Services. Healthcare and Public Health Sector Cybersecurity Performance Goals.
- U.S. Department of Health and Human Services. Fact Sheet: Ransomware and HIPAA.
- U.S. Department of Health and Human Services. Ransomware & Healthcare.
- Federal Bureau of Investigation. Ransomware.